

INFORME DE SEGURIDAD DEL SISTEMA

SST Colombia

Documento de referencia para implementación de seguridad

Fecha de generación: 17 de febrero de 2026

1. AUTENTICACIÓN Y CONTRASEÑAS

- **Algoritmo de hash:** scrypt con sal aleatoria de 16 bytes (128 bits) y clave derivada de 64 bytes (512 bits)
- **Formato almacenado:** hash_hex.salt_hex (nunca se guarda la contraseña en texto plano)
- **Comparación segura:** timingSafeEqual para evitar ataques de tiempo
- **Validación de contraseñas:** mínimo 6 caracteres con validación Zod
- **Sesiones:** Express-session con almacenamiento en base de datos
 - Cookie httpOnly: true (no accesible desde JavaScript del navegador)
 - Cookie secure: true en producción (solo HTTPS)
 - Cookie sameSite: 'strict' (protección contra CSRF)
 - Tiempo de expiración: 12 horas
- **Función stripPassword():** remueve el hash de toda respuesta de la API

2. CONTROL DE ACCESO (RBAC) - 14 ROLES

Roles: superadmin, soporte, superusuario, admin, responsable_sst, coordinador_salud, Iso, coordinador_sst, coordinador_rrhh, jefe_personal, supervisor, vigia_sst, auditor_interno, trabajador

- **Middleware requireRole():** para control por rol
- **Middleware requirePermission():** para control granular por permisos
- Sistema de permisos tipo recurso:acción
- Aislamiento multi-tenant: cada usuario solo accede a datos de su empresa

3. CIFRADO DE DATOS EN REPOSO (Ley 1581/2012)

- **Algoritmo:** AES-256-GCM (Galois/Counter Mode)
- **Llave maestra:** 256 bits, variable de entorno
- **Derivación de llaves por campo:** HMAC-SHA256 con contexto único
- **Campos cifrados de trabajadores:**
 - nombre, cédula, teléfono, dirección, condiciones de salud, historial médico
 - contacto de emergencia, cuenta bancaria, fecha de nacimiento
 - grupo sanguíneo, alergias, medicamentos, discapacidades
- **Campos cifrados de empresas:**
 - NIT, dirección, teléfono, nombre y datos del representante legal
- **Hashing para búsqueda:** campos como cédula tienen hash adicional para búsqueda indexada sin descifrar

4. RATE LIMITING (Protección contra ataques)

Endpoint	Límite	Propósito
Login	5 intentos / 15 min	Protección contra fuerza bruta
Registro	3 intentos / 1 hora	Creación masiva de cuentas
Reset contraseña	3 solicitudes / 1 hora	Bombardeo de emails
Facturación	100 requests / 15 min	Abuso de API
Mutaciones suscripción	20 requests / 15 min	Manipulación
Operaciones de pago	10 requests / 15 min	Fraude
Webhooks	1000 requests / 15 min	DDoS

5. LOGGING Y AUDITORÍA

- **Logger estructurado Pino:** JSON en producción, formato legible en desarrollo
- **Contexto por request:** requestId, companyId, userId
- Redacción automática de datos sensibles en logs (contraseñas, tokens, sesiones, cédulas, datos médicos)
- **Audit Logger:** registra todas las operaciones CRUD sobre entidades reguladas
- **Cumple:** Ley 1581/2012, Decreto 1074/2015 (retención 20 años), Resolución 2346/2007

6. VALIDACIÓN DE DATOS

- Zod en todas las rutas del servidor (861+ validaciones)
- Schemas compartidos frontend/backend (drizzle-zod)
- Conversión de strings vacíos a null para campos opcionales

7. PROTECCIÓN DE PAGOS (Stripe)

- Verificación de firma de webhooks con STRIPE_WEBHOOK_SECRET
- Rate limiting específico para operaciones de pago
- Verificación JWT con HMAC-SHA256 para precios desde landing page

8. BACKUPS AUTOMATIZADOS

- **Frecuencia:** Semanal (domingos 11PM hora Colombia)
- **Método:** pg_dump de PostgreSQL
- **Cifrado:** AES-256-CBC con password de entorno
- **Almacenamiento:** Upload a AWS S3

9. CONTROL DE SUSCRIPCIONES

- **Feature Gate:** middleware que bloquea acceso a módulos premium según plan
- **Subscription Check:** verifica estado de suscripción
- Bloqueo automático cuando vence o falla el pago
- Período de gracia configurable

10. PROTECCIÓN DE DOCUMENTOS PDF

- Marca de agua en PDFs de prueba: "VERSIÓN DE PRUEBA - NO VÁLIDO PARA AUDITORÍA"

- Estandarización corporativa de todos los PDFs
- Trazabilidad centralizada de documentos generados

11. SISTEMA DE LICENCIAS

- Verificación periódica cada 5 minutos
- Modo solo lectura si la licencia es inválida
- Hash SHA-256 de la llave para transmisión segura

12. MULTI-TENANCY

- Cada empresa es un tenant aislado
- Los usuarios solo acceden a datos de su empresa (companyId)
- Aislamiento a nivel de consultas de base de datos

TABLA RESUMEN DE TECNOLOGÍAS

Componente	Tecnología
Hash de contraseñas	scrypt + salt aleatorio
Cifrado de datos	AES-256-GCM
Derivación de llaves	HMAC-SHA256
Sesiones	express-session + PostgreSQL store
Rate limiting	express-rate-limit
Validación	Zod
Logging	Pino (JSON estructurado)
Pagos	Stripe (webhook signature verification)
JWT	HMAC-SHA256
Backups	pg_dump + AES-256-CBC + S3

